Static Analysis in Practice

We acknowledge funding provided by Microelectronic Commons and the support of OUSW(R&E).

Static Analysis on Edge device

- Offensive/Red teaming -> You get the device.
- Defensive -> Source Code.

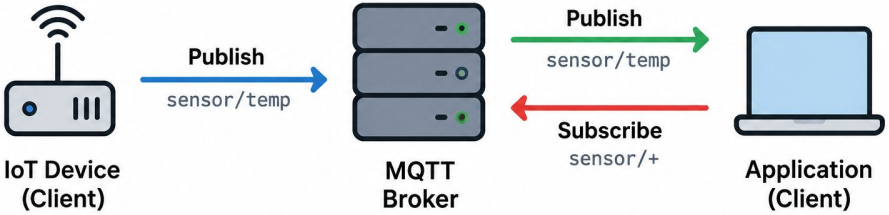
Common classes of Vulnerabilities

- OS Vulnerabilities.
- Application Protocol Vulnerabilities.
- Insecure pairing/spoofing.
- Weak authentication, weak cryptographic primitives.
- Information leakage --- debug logs!

Application Protocol Vulnerabilities

MQTT, CoAP, Websocket

MQTT


Publish
sensor/temp
Publish
sensor/temp
Subscribe
sensor/+
IoT Device
(Client)
MQTT
Broker
Application
(Client)

Common vulnerabilities in MQTT

- Missing authentication.
- Unauthorized publishing.
- Topic Leakage.
- Denial of Service.

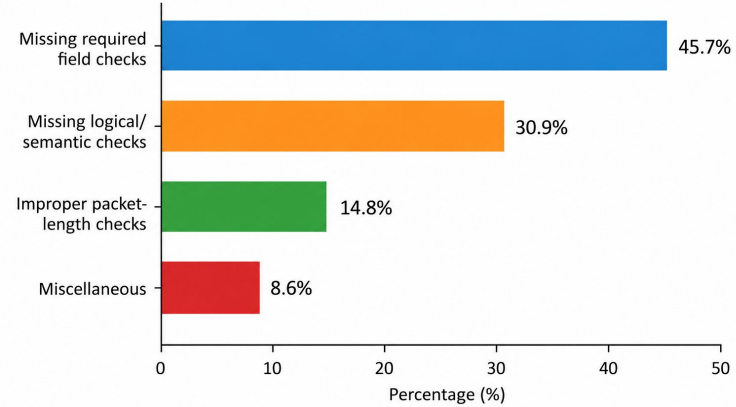
Common vulnerabilities in MQTT

- 88% has no authentication.

A Large-Scale Empirical Study on the Vulnerability of Deployed IoT Devices

Binbin Zhao, Shouling Ji, *Member, IEEE*, Wei-Han Lee, Changting Lin, Haiqin Weng, Jingzheng Wu, Pan Zhou, *Senior Member, IEEE*, Liming Fang, and Raheem Beyah, *Senior Member, IEEE*

Vulnerability Distribution



Preventing MQTT Vulnerabilities Using IoT-Enabled Intrusion Detection System

Muhammad Husnain [1], Khizar Hayat [1], Enrico Cambiaso [2,*], Ubaid U Fayyaz [1], Maurizio Mongelli [2], Habiba Akram [1], Syed Ghazanfar Abbas [1], Ghalib A Shah [1]

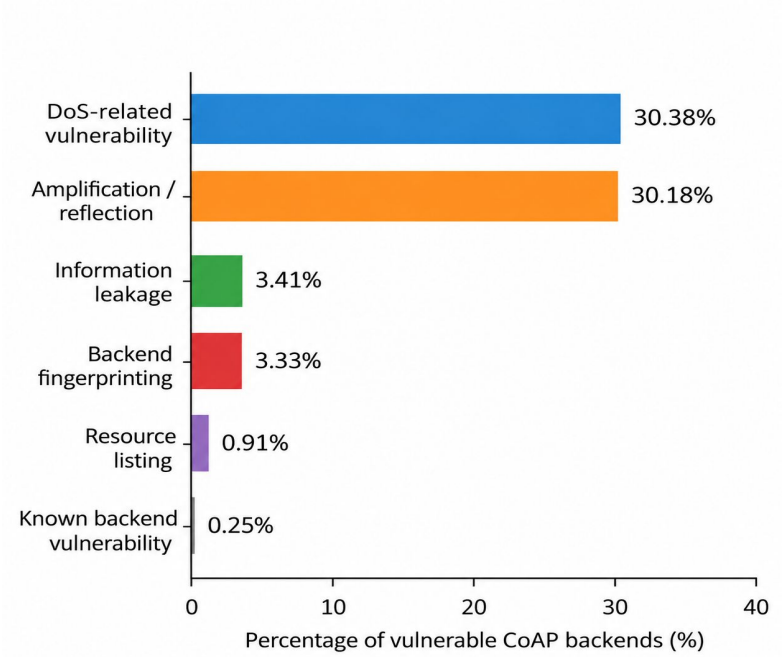
Missing Validation Checks in MQTT

Cesanta Mongoose MQTT getu16 Heap Buffer Qverflow

Summary

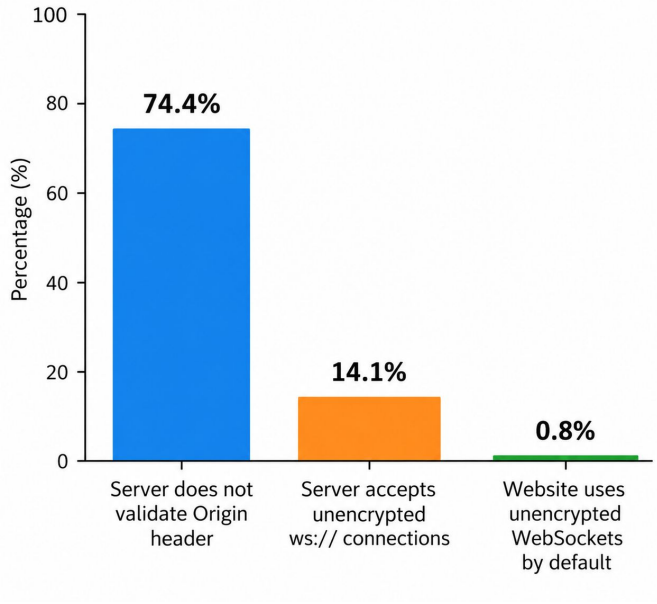
- An exploitable arbitrary memory read vulnerability exists in the MQTT packet parsing functionality of Cesanta Mongoose 6.13. A specially crafted MQTT SUBSCRIBE packet can cause an arbitrary out-of=bounds memory read potentially resulting in information disclosure and denial of service. An attacker needs to send a specially crafted MQTT packet over the network to trigger this vulnerability.

CoAP (REST for IoT)



https://kevin.borgolte.me/files/pdf/raid2024-iot-backends.pdf

Websocket



WebSocket Adoption and the Landscape of the Real-Time Web

Paul Murley
University of Illinois at Urbana-Champaign
pmurley2@illinois.edu

Zane Ma
University of Illinois at Urbana-Champaign
zanema2@illinois.edu

Joshua Mason
University of Illinois at Urbana-Champaign
joshm@illinois.edu

Michael Bailey
University of Illinois at Urbana-Champaign
mdbailey@illinois.edu

Amin Kharraz
Florida International University
mkharraz@fiu.edu